EU CYBER RESILIENCE ACT · COMPLIANCE CHECKLIST · 2026 EDITION

WESLEY AI INC.

Deadline: 11 Dec 2027

CRA 合規自評清單

Taiwan Manufacturer Self-Assessment Checklist

針對出口歐盟的工業設備 / OT / IoT 產品製造商。完成後預約免費 30 分鐘 Gap 診斷。

wesleyai.com.tw

1 產品範疇確認 · Product Scope

- [ ] 產品含數位元件（韌體 / 軟體 / 通訊介面）？
  Does the product contain digital elements — firmware, software, or network interfaces?
- [ ] 產品直接或間接連接網路（有線 / 無線 / 藍牙 / NFC）？
  Does it connect to a network, directly or indirectly?
- [ ] 確認產品不在 CRA 豁免清單內
  Verify product is not excluded (e.g. open-source non-commercial, national security, medical per MDR/IVDR)
- [ ] 確認產品風險等級：Default / Class I / Class II 重要
  Risk classification determines conformity route — self-declaration vs. Notified Body involvement

2 資安要求 · Cybersecurity Requirements (Annex I Part I)

- [ ] 產品出廠時無已知可利用漏洞 技術文件必備
  No known exploitable vulnerabilities at time of placing on market
- [ ] 預設安全設定（Secure by Default）：無預設通用密碼
  Secure by default — no universal default passwords or easily guessable credentials
- [ ] 具備身份驗證 / 授權機制
  Authentication and access control mechanisms implemented
- [ ] 傳輸中資料加密（TLS 1.2+ 或等效）
  Data in transit protected by encryption (TLS 1.2+ or equivalent)
- [ ] 靜態敏感資料加密
  Sensitive data at rest protected by encryption
- [ ] 攻擊面最小化（關閉不必要服務 / 連接埠）
  Minimise attack surface — disable unused services, ports, and interfaces by default
- [ ] 具備安全更新 / 韌體升級機制 OTA 必須
  Mechanism for security updates and firmware upgrades in place
- [ ] 使用者可重設產品至安全出廠狀態
  User can reset device to a secure factory state
- [ ] 安全事件記錄（Log）功能
  Security event logging capability for incident investigation

3 漏洞管理 · Vulnerability Handling (Annex I Part II)

- [ ] 建立漏洞揭露政策（VDP）並公開聯絡管道 Annex I 必要
  Vulnerability Disclosure Policy (VDP) published with public contact channel
- [ ] 產品支援期間（最少 5 年）內提供安全更新
  Security updates provided throughout support period — minimum 5 years
- [ ] 開源元件清單（SBOM）已建立並可提供主管機關 SBOM
  Software Bill of Materials (SBOM) documented — all open-source components listed
- [ ] 已訂定漏洞回應 SLA（發現 → 修補 → 通報）
  Vulnerability response SLA defined: discovery → patch → notification timeline
- [ ] 主動監控 CVE / NVD 資料庫中涉及本產品元件的漏洞
  Active monitoring of CVE/NVD for vulnerabilities affecting product components

4 技術文件與符合性聲明 · Documentation & Declaration of Conformity

- [ ] 技術文件（Technical Documentation）已按 Annex VII 準備 出口必備
  Technical documentation per Annex VII — covers design, security controls, test results
- [ ] EU 符合性聲明（DoC）草稿完成
  Draft EU Declaration of Conformity (DoC) — includes standards cited and conformity route
- [ ] CE 標誌使用條件確認（Class II 需 Notified Body）
  CE marking conditions confirmed — Class II products require Notified Body involvement
- [ ] 已識別適用的調和標準（IEC 62443 / EN 303 645 等） 標準對應
  Applicable harmonised standards identified: IEC 62443-4-2, EN 303 645, ETSI EN 17927

5 事件通報 • Incident Reporting (Article 14)

- ☐ 主動遭利用漏洞需於 24 小時內通報 ENISA / 主管機關 **24h**
  Actively exploited vulnerabilities: notify ENISA / market surveillance authority within 24 hours
- ☐ 重大資安事件需於 72 小時內提交初步報告 **72h**
  Significant cybersecurity incidents: initial report within 72 hours
- ☐ 已識別台灣出口歐盟的對口市場監督機關（MSA）
  Identified the relevant Market Surveillance Authority (MSA) in the EU target market(s)

完成項目 / Total Checked

_____ / 21 項

0–10 高風險　11–17 需補強　18–21 接近合規

想知道你的 Gap 在哪裡？

預約免費 30 分鐘 CRA Gap 診斷，由 Wesley LIN 親自評估

wesleyai.com.tw · Wesley LIN 林靖為 • President, Wesley AI Inc.

© 2026 Wesley AI Inc. 衛斯理股份有限公司 • Taoyuan, Taiwan · This checklist is for self-assessment only and does not constitute legal advice.